

Privacy and Access Control Rules

PondLite stores emotionally personal relationship data, so privacy and access control must be treated as core design requirements rather than later add-ons.

1. All relationship content belongs to a Relationship/Pond.
2. A user may only view, create, update, or delete relationship content if they are a member of that Relationship/Pond.
3. If the system cannot verify that a user is a member of the requested Relationship/Pond, access should be denied by default.
4. Check-ins, notes, discussion responses, reminders/ribbits, AI suggestions, and frog states are private to the Relationship/Pond.
5. Authentication tokens identify the user, but RelationshipMember records determine what relationship spaces the user can access.
6. AI suggestions should only receive the minimum context needed to generate a suggestion.
7. AI suggestions are optional and user-controlled. The AI does not automatically message a partner, complete a reminder, or make decisions.
8. Private Raspberry Pi/Tailscale deployment is intended only for trusted early users and should not expose the application or database directly to the public internet.
9. A future public version will require stronger production privacy protections, including secure hosting, account deletion, data deletion, privacy policy, backups, monitoring, and production-ready authentication.